

5. Avaliação de terceiros críticos

Após o exercício inicial de mapeamento, a InterMed concluiu que depende de alguns terceiros cuja falha pode ter impacto elevado na operação e na estratégia digital. Apesar disso, a maturidade interna para avaliação estruturada de terceiros continua baixa: não existe política formal de supply chain security, os contratos variam muito em qualidade, não há checklist de due diligence de cibersegurança e a organização não tem prática consolidada de classificar fornecedores por criticidade e aplicar controlos proporcionais.

O responsável de segurança propôs iniciar um modelo simples de avaliação para três terceiros prioritários: fornecedor do DCE, cloud provider do portal/app e fornecedor de faturação eletrónica. O objetivo é adotar uma abordagem inspirada em boas práticas como a família ISO 27036 e nos requisitos da NIS2 para supply chain security, sem criar um processo demasiado pesado para uma organização com baixa maturidade. Pretende-se identificar o nível atual, perceber lacunas e definir uma checklist mínima que passe a ser usada em novas contratações e revisões contratuais.

No entanto, a análise interna mostra que a InterMed ainda não domina bem os seus próprios requisitos. Nem sempre sabe que informação pede aos fornecedores, não tem um modelo claro de evidências aceitáveis, não integra compras, jurídico e segurança num processo único, e não tem critério uniforme para exigir cláusulas sobre incidente, auditoria, continuidade, vulnerabilidades ou subcontratação. Isto significa que o exercício deve começar por avaliar não apenas o fornecedor, mas também a maturidade da própria InterMed enquanto cliente que gere risco de terceiros.

Assume-se ainda que nenhum dos três fornecedores foi submetido nos últimos 24 meses a uma revisão formal de segurança; não existe inventário consolidado de acessos privilegiados concedidos a terceiros; e os questionários anteriores, quando existiram, foram sobretudo administrativos e não orientados ao risco.

Dados adicionais para análise

- Não existe política corporativa de third-party security.
- Não existe critério único de classificação de fornecedor crítico.
- Não há direito de auditoria em vários contratos antigos.
- A gestão de vulnerabilidades dos fornecedores não é acompanhada regularmente.

- Não há processo formal de due diligence pré-contratual de cyber.
- Não existe processo forte de reassessment periódico.
- As áreas de compras e IT atuam muitas vezes sem envolvimento antecipado da segurança.

Questões

1. Avalie a maturidade atual da InterMed na gestão de terceiros críticos.
2. Identifique as principais lacunas.
3. Indique que evidências pediria a um fornecedor crítico.

Segue uma grelha simples e utilizável em aula para a “Folha de resposta – Nível de maturidade atual na avaliação de terceiros”, alinhada com o espírito da NIS2 (supply chain security, diretório de fornecedores, due diligence, etc.). [ENISA-NIS2-Technical implementation guidance 1.0.pdf](#)

Grelha de resposta – Nível de maturidade atual na avaliação de terceiros

A. Classificação global de maturidade

Dimensão	Nível (1–5)	Evidências / Observações
Política e governação de terceiros		
Processo de avaliação e due diligence		
Diretório / inventário de fornecedores		
Criticidade e classificação de terceiros		
Cláusulas contratuais de segurança		
Monitorização contínua e reavaliação		
Integração com gestão do risco (ERM/NIS2)		

Legenda sugerida de níveis

1 – Inexistente | 2 – Inicial | 3 – Básico | 4 – Intermédio | 5 – Avançado

Evidências existentes

Área	Evidência existente	Lacuna identificada
Política / normas		
Contratos / SLAs		
Registo de fornecedores		
Registos de avaliações passadas		
Registos de incidentes com terceiros		

Checklist adicionar de avaliação de terceiros

- O fornecedor tem política de segurança e governance definidos?
- Existem certificações ou evidências equivalentes?
- Existe processo de gestão de incidentes e obrigação de notificação?
- Há gestão de vulnerabilidades e patching?
- Existem controlos de acesso e MFA para acessos privilegiados?
- Existem backups, testes de continuidade e DR?
- O fornecedor controla subcontratados críticos?
- O contrato prevê direito de auditoria?
- Existem SLAs e métricas de segurança?
- Existe plano de saída/termination?
- O fornecedor protege dados sensíveis adequadamente?
- Existem testes ou auditorias periódicas?